Software Engineering & Security Principles: Milestone 1

Logan K. Grace

Grand Canyon University

SWE-550-0500: Software Engineering & Security Principles

Hatim Alzoubi

Due: 11-4-2026

Revision: -

Milestone 1: Project Proposal and Security Requirements

GitHub Repository: LGrace9784/appointment-scheduling: appointment software that allows the user to log in and book appointments

Project Proposal and Secure Development Rationale

The project being designed is an online appointment scheduling system that will give a secure and easy way for clients to look for appointment times, book and cancel appointments, and get a confirmation message. Select staff will be allowed access to manage records and appointments on the inside if needed. The initial push will serve one organization and prioritize the overall consideration of the user.

That target is the users, staff, and administrators. Clients will be able to create accounts, look at appointments, and manage their bookings. Staff will be able to manage the availability timeframe as needed. Administrators will be able to alter staff roles and any configuration in the program. The features included will be the general features for a program like this. They are sign-in/registration, role access, booking, availability, reschedule, cancellation, notifications, and administration appointment review. The information being stored is emails, usernames, optional cell phone numbers, password hashes, roles, service types, availability, notification preferences, and security audits. Payment information will not be kept in this system or anything that may be deemed too sensitive for storage.

The business value is that it provides a clean system that allows all parties involved to have an easy method to manage an appointment. The timeline is realistic because it creates a framework with limited roles and a reasonable database. It will start with the requirements and design, then shift to authentication and data model, then to the booking stage, then notifications,

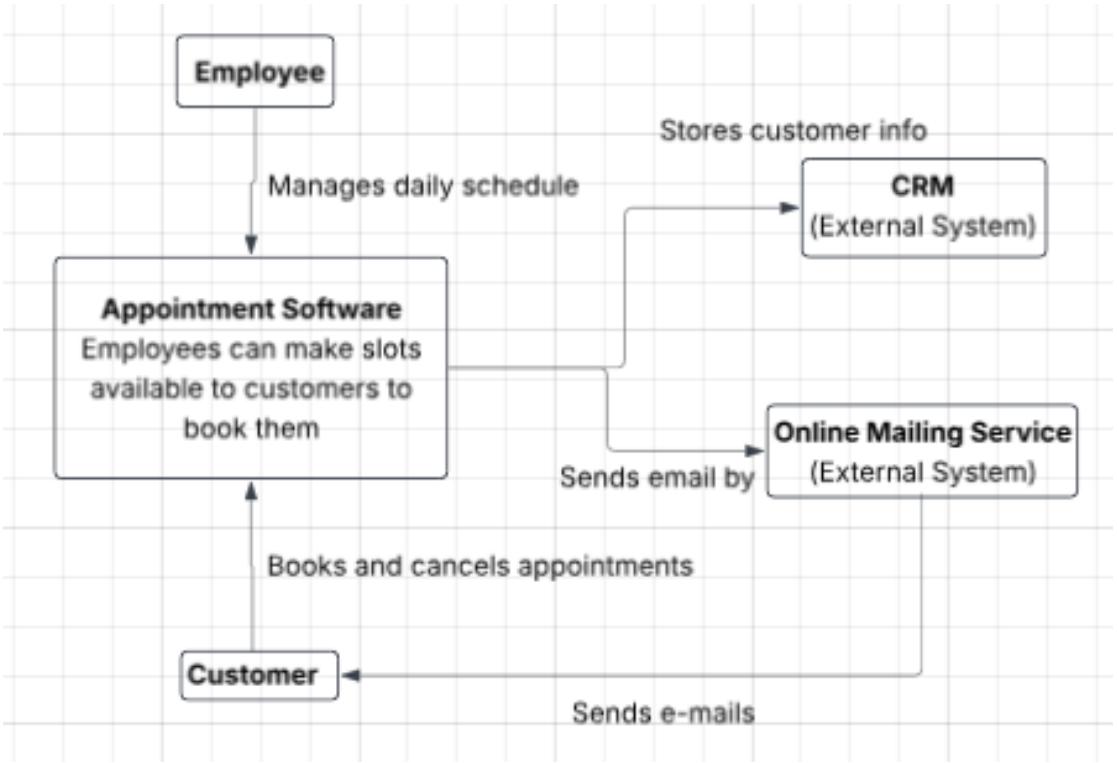
then testing, and ending with acceptance. Everything else, like payment processing and advanced analytics, will be outside of the first release.

Security in development is more of a requirement throughout the whole SDLC no matter what the product is if it is to the public. Threats and trust boundaries are being found before design choices become hard to change. This allows data minimization and secure credential handling for the whole system. Adding security after implementation usually requires costly rework and leaves insecure assumptions in the workflow. This is why the security must be a continuous quality attribute rather than a final checklist item in the system.

Stakeholder and System Context Analysis

Clients use the public application to register and manage appointments. Staff use a protected portal to publish the hours, review the appointments, and update the appointment status. Administrators provision accounts, assign the roles, and handle the data. An external/SMS service sends confirmation and reminders. There may be an addition of identity provider that can support a federated log in, local will do fine for this application.

All requests enter through the HTTPS web/API layer. Authentication and access-control services confirm the identity and permissions. The scheduling service reads and updates appointment information that is in the database. Notification messages cross the application boundary to the 3rd party provider. If an identity provider is in place, tokens cross that boundary and must be confirmed. The database is not accessible to external users.



Asset, Trust Boundary, and Abuse Casee Analysis

The application must protect different areas. It must protect client information like identity and password information. The appointment and staff status along with the roles. Keep the cookies okay combined with the tokens. Notification content, delivery addresses, application configuration, cryptographic keys, and service availability are all protected assets that need to be a factor.

When it comes to the trust boundaries, there are five that come to mine. Public client devices to the HTTPS application at entry point. Staff devices to the privileged functions. Application services to the database and secrets store. Application to email provider and the application to the optional external provider. Every cross requires the needed validation and encryption needed.

There are different abuse scenarios that can be done. An attacker can perform credential stuffing or account enumeration. It risks the assets of identity data, passwords hashes, and

availability with the actor being the external attacker. A client can alter an appointment ID to view or cancel a client's appointment. The assets are appointment records and privacy with the actor being improper authenticated client. A script can submit concurrent bookings to reserve all the unavailable times. The assets are the scheduling and availability, and the actor would be the bot. An exposed staff account changes the availability of bookings The assets are schedules, appointments, and overall integrity with the actor being the thief. Malicious input attempts by SQL injection or bad code execution. The assets are the database, and the actor is the external user. An exposed notification provider account exposes the appointment information. The assets are contact information and appointment privacy with the actor being the vendor account. The last is a denial-of-service flood attacking the availability. The asset is service availability with the actor being an individual or even a bot.

Security Requirements and Risk Traceability

This table below represents the security solution to the threat level mentioned above. The associated threat level is in order as appears above

ID	Requirement	Stakeholder or Asset	Threat	Risk Reduction
SR-01	Store passwords only as satled hashes	Clients and credentials	AC1	Limits damage from credential exposure
SR-02	Require authenticated session for protected functions and enforce server-side role authorization	All roles with appointments and permissions	AC2, AC4	Blocks access beyond the user's permission
SR-03	Confirm appointment ownership before a client can view or make changes	Clients and appointment records	AC2	Prevents cross-client record access
SR-04	Atomical bookings and availability checking	Clients/staff and schedules	AC3	Prevents double bookings
SR-05	TLS is used for external connections and secure sessions	All users with sessions and contact data	AC1, AC6	Protects data in transit and reduces session theft
SR-06	Validate and encode input server-side	All users and database	AC5	Reduces injection and unsafe-rendering risks
SR-07	Require MFA for staff and admin	Staff/admin with roles and schedules	AC4	Reduces the impact of stolen passwords

SR-08	Rate-limit authentication and availability requests	All users with service availability	AC1, AC7	Slows credential attacks
SR-09	Log security resolutions	Admin with audit logins	AC2, AC4, AC6	Supports investigation without keeping secrets
SR-10	Minimize appointment informations	Clients with notification data	AC6	Limits disclosure if message are misdirected

Societal and Global Security Factors

First, we must look at privacy and data protection regulations. Appointment information can show private patterns even if sensitive information is not collected. Names and appointment times should be handled like private information. Privacy laws change by the jurisdiction, so location does matter where the user is using it. This raises appointment metadata and notification content in the asset inventory. Ethical responsibilities include collecting and managing all day through proper practices. The 3rd, 9th, and 10th cases above support privacy through access restrictions, minimizing log information, and limited notification. A retention schedule and privacy notice should be defined with legal review required if the system handles medical or other sectors where more data becomes sensitive.

Users may use the system from different devices and other technologies used outside of normal expectations. Shared devices can expose sessions and introduce extra risk into the program. Internation use can introduce time zone issues when establishing appointments. The system should give secure session handling and proper error messages as safeguards for the system. Rate limits will avoid unfairly blocking the user who shares network access. These help the 5th and 8th situation outlined above and require more tests. Security must protect the users without excluding other users with different methods of technology.

Project Backlog and Security Implications

Story	User Story	Security Concern
US-01	Register by email to manage appointments	Verify email, validate input, limit profile data, and prevent account enumeration
US -02	Secure sign in for returning user	Adaptive password hashing, safe sessions, and rate limits
US -03	Role based access to the functions required for work	Authorization server-side, never trust client-submitted role values
US -04	View available times to select slot	Not exposing clients identities or appointment details
US -05	Book available time	Atomic availability checks and booking writes to prevent double booking
US -06	Reschedule or cancel booking	Verify record ownership and authorization on each request
US -07	Publish working hours and availability	Restrict changes to authorized staff and audit schedule changes
US -08	Confirmations and reminders	Verify destinations, limit message content, protect provider credentials
US -09	Review of security activity	Protect logs from alteration, tokens, and excessive personal data
US -10	View upcoming and past appointments	Return only the logged in clients records and paginate results
US -11	Clear validation and error messages	Do not expose stack traces, database details, or internal configuration
US -12	Configure access policies	Restrict configuration to administrators and review policy change

Work Related Statement

The project being accomplished is not related to any current work. Any work done has no ties to any external company nor can they claim this work. All work in this project is done exclusively and independently.